

Eng 5.1. Intro to IR and IM

Intro to IR and IM

Task 1 - Introduction

Cyber Incidents are a part of life at this point. The question is no longer if an organisation will have an incident but when.

Task 2 - What is Incident Response and Management

Event: An **event** is any activity that occurs on a system, network, or application. Events can be normal or suspicious and are recorded in logs for monitoring and analysis.

Alert: An **alert** is a notification generated by a security tool when it detects potentially suspicious or malicious activity. Alerts indicate something that may require investigation.

Incident: An **incident** is a confirmed security event that violates security policies or poses a threat to systems, networks, or data. Incidents require response actions to contain and resolve the issue.

Cyber Incident: A **cyber incident** is a security incident involving cyber threats that affect the confidentiality, integrity, or availability of information systems. Examples include malware infections, data breaches, ransomware attacks, and unauthorized access.

Incident Response (Technical Focus)

- Answers the question: "**What happened?**"
- Investigates alerts from tools such as **EDR/AV, Network Taps, and SIEMs**.
- Uses digital forensics when more information is needed, including:
 - Disk analysis
 - Memory (RAM) analysis
 - System and network log analysis

- Goal: Determine the **scope and impact** of the incident to ensure the correct response.

Incident Management (Process Focus)

- Answers the question: "**How do we respond?**"
- Manages the incident lifecycle by:
 - Assessing severity and involving stakeholders
 - Following response playbooks
 - Making containment, eradication, and recovery decisions
 - Managing internal and external communications
 - Documenting actions and lessons learned
 - Closing the incident and improving future processes

Incident Response Levels

Level 1: SOC Incident

- Small, isolated security event.
- Usually handled by a single analyst.
- Example: Blocking a phishing email sender.
- Minimal business impact.

Level 2: CERT Incident

- Suspicious activity requiring deeper investigation.
- Multiple SOC analysts become involved.
- Goal: Determine whether the threat has spread or been interacted with.
- Example: Investigating whether users clicked a phishing email.

Level 3: CSIRT Incident

- Confirmed security incident with broader impact.
- Entire SOC focuses on containment, eradication, and recovery.
- Forensics teams investigate the full scope.

- Example: Malware infection affecting multiple systems.

Level 4: CMT Incident (Cyber Crisis)

- Organization-wide cyber crisis.
- Executive leadership, legal, communications, regulators, and law enforcement may become involved.
- Can authorize major actions such as taking systems or the entire organization offline.
- Example: Large-scale ransomware attack or major data breach.

Incident Response focuses on understanding **what happened**, while **Incident Management** focuses on deciding **how to respond**. As incidents become more severe, they escalate from **SOC** → **CERT** → **CSIRT** → **CMT**, involving more people, resources, and business-impacting decisions.

Benefits of Incident Response and Management

- **Reduces the impact of cyberattacks** by enabling faster detection, containment, and recovery.
- **Minimizes financial losses** caused by downtime, data breaches, and business disruption.
- **Protects an organization's reputation** and maintains customer trust.
- **Improves business continuity** by ensuring critical systems can be restored quickly.
- **Supports regulatory compliance** and legal requirements.
- **Provides lessons learned** to strengthen future security controls and processes.
- **Coordinates technical and business responses** during security incidents.

Building and maintaining an Incident Response and Incident Management capability requires significant investment, but the cost of not having one can be much greater. Cyber incidents can severely damage organizations, and studies suggest that many small businesses fail within months of a major cyberattack. Effective incident response helps organizations survive, recover, and improve their security posture.

Answer the questions below

At what level (number only) of an incident would the SOC be placed at high alert and to deal with an incident?

3

At what level (number only) of an incident would it be classified as a cyber crisis?

4

Which component (IR or IM) is responsible for trying to answer the question: How do we respond to what happened?

IM

Which component (IR or IM) is responsible for trying to answer the question: What happened?

IR

Task 3 - The Different Roles During an Incident

Role	Description
SOC Analyst	A SOC analyst is a person that deals with the various events and alerts that happen in the SOC. There are usually different levels of analysts. Ultimately, analysts are usually some of the first members that would get involved in dealing with an incident.
SOC Lead	The SOC lead, also called the SOC Manager or Head of SOC, is responsible for dividing the tasks in the SOC and deciding to escalate an alert to the level of incident. Usually, the SOC manager understands the technical information required to perform an investigation to better help them divide the different tasks during an incident.
Forensic Analyst	A forensic analyst is a person that performs an investigation to better understand what happened during an incident. This is often digital forensics that must be investigated by

	reviewing artefacts such as the memory or hard drive of a device.
Malware Analyst	A malware analyst is a forensic analyst who focuses on understanding how the malware works. These analysts often have significant technical capabilities to debug and decompile malware to understand how it works. These analysts often help to uncover Indicators of Compromise (IoCs) that are signatures of the malware that can be used to identify the malware in the environment.
Threat Hunter	A threat hunter is a person that actively tries to uncover new threats in the environment. The goal of threat hunting is to try and create new alert rules based on information available in logs and other sources. By performing threat hunting, an alert would be generated that could help the team discover an attacker that attempted to use the same technique.
First Responder	In certain cases, it isn't actually the SOC that is first alerted to an incident. Often, a cyber incident could have started as a business incident. For example, a product team discovers that their application has slowed down and isn't responding as it should. In these cases, that team becomes the First Responders to the incident. While they would not be expected to deal with the entire incident by themselves, there are some key steps that first responders should take to ensure that they don't compromise information that will be required to better understand the cyber incident.
Security Engineer	While security engineers are not directly involved with the SOC, they can often be involved in incidents. Security engineers are responsible for the security of their division, application, or system. In the event that there is an incident in their area, they will often be relied upon as a subject matter expert to aid in the investigation. Furthermore, security engineers will often work closely with the SOC to ensure that the SOC is receiving log information from their division.
Information Security Officer	Similar to a security engineer, an information security officer (ISO) is responsible for the security of their division. However, this is usually more management focussed than technical, such as security engineers. ISOs are also often involved in incidents as subject matter experts and responsible for acting as the bridge between the Incident

	Response team and their division team that will have to implement the actions provided by the Incident Manager.
Incident Manager	An incident manager is a person that was trained in performing the management duties for Incident Response and Management. Incident Managers have to be exceptional in note-taking and organised to ensure that everything during an incident is properly documented and that the processes are followed.
Project Owner	A product owner is usually the person that takes the lead during the development of a solution. In the past, with the waterfall method, products were only released after they were fully completed. However, today, using Agile processes, products are released and continuously updated. As such, since a version of the project is already live as the team is still performing development, incidents can already occur. In the event of an incident, the product owner is often called in as a subject matter expert to help with the investigation.
Subject Matter Expert	The blue team cannot be expected to be experts in every single technology or system. As such, Subject Matter Experts (SMEs) are often relied upon based on the specific incident at hand. For example, if, in the incident, Active Directory has been compromised, one of the Domain Admins could be called in as an SME. SMEs are often relied on to provide more information that allows the blue team to better understand the incident scope and what potential actions can be taken against the threat actors.
Crisis Manager	A crisis manager is the lead for the crisis management team. This is usually an executive such as the CIO or COO. This person is responsible for ensuring that the CMT functions as they should and can deal with the crisis.
Executive	In the event that an incident is sufficiently severe, executives of a company will be involved in the CMT. This includes the CEO, COO, CIO, CTO, and CISO.

Answer the questions below

What is the value of the flag you receive after matching the roles and responsibilities?

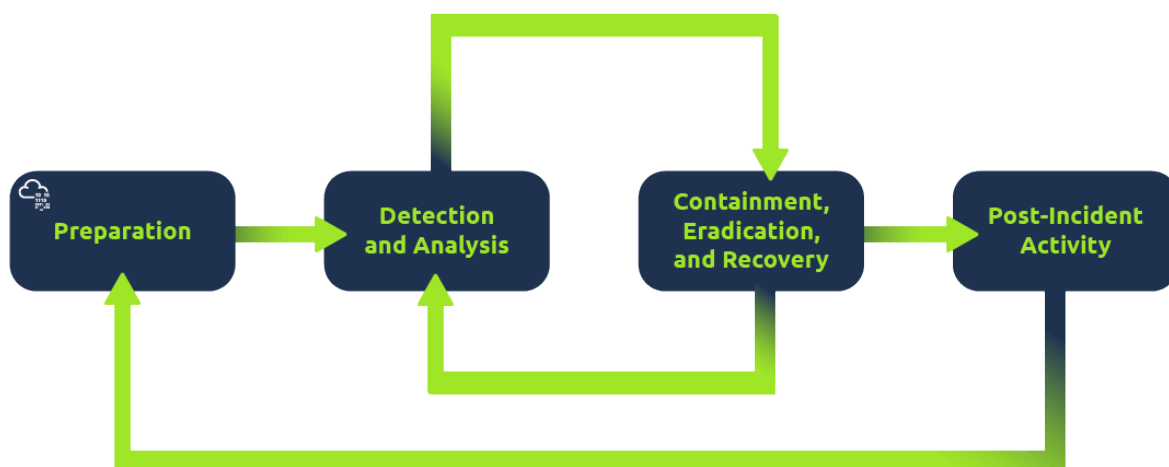
THM{Roles.and.Responsibilities.of.IR.and.IM}

Progress: 67% Correct: 7/8

Description	Role
Investigates alerts in the SIEM to determine if these events are true positives and an incident should be raised.	SOC Analyst
Can be a member of the crisis management team and responsible for making difficult decisions during the incident	Executive
The team that is called upon if the incident is sufficiently serious that there may be significant business impact	CMT
The team that is called upon if the incident is sufficiently serious that a full investigation is required	
The person that first discovered the incident and has to follow a specific process to make sure that the evidence remains intact	First Responder
Someone that has expert knowledge in a specific field or area that can be useful if there is an active incident pertaining to something in their field	SME
The business owner of a specific application or service. This person is responsible for making decisions regarding the asset that they look after	Product Owner
The person that performs a detailed investigation in the incident evidence to try and uncover clues as to what has happened and what may happen next	Forensic Analyst

CSIRT

Task 4 - The Process of Incident Management



1. Preparation: Preparation ensures teams can respond quickly and effectively during an incident.

- Identify stakeholders and communication/call trees.
- Create and maintain incident response playbooks.
- Conduct tabletop exercises and cyber war games.
- Perform threat hunting and improve detection rules.

2. Detection and Analysis: The goal is to determine **what happened** and understand the incident's scope.

- Review alerts from AV, EDR, and SIEM tools.
- Perform digital forensics on systems and networks.
- Analyze malware and create detection signatures.
- Assess and triage the severity of incidents.

3. Containment, Eradication, and Recovery: The goal is to stop, remove, and recover from the threat.

- **Containment:** Limit the spread of the incident.
- **Eradication:** Remove the threat actor and malicious artifacts.
- **Recovery:** Restore systems and return to normal operations (BAU).

4. Post-Incident Activity: After the incident is resolved, the team reviews what happened and identifies lessons learned.

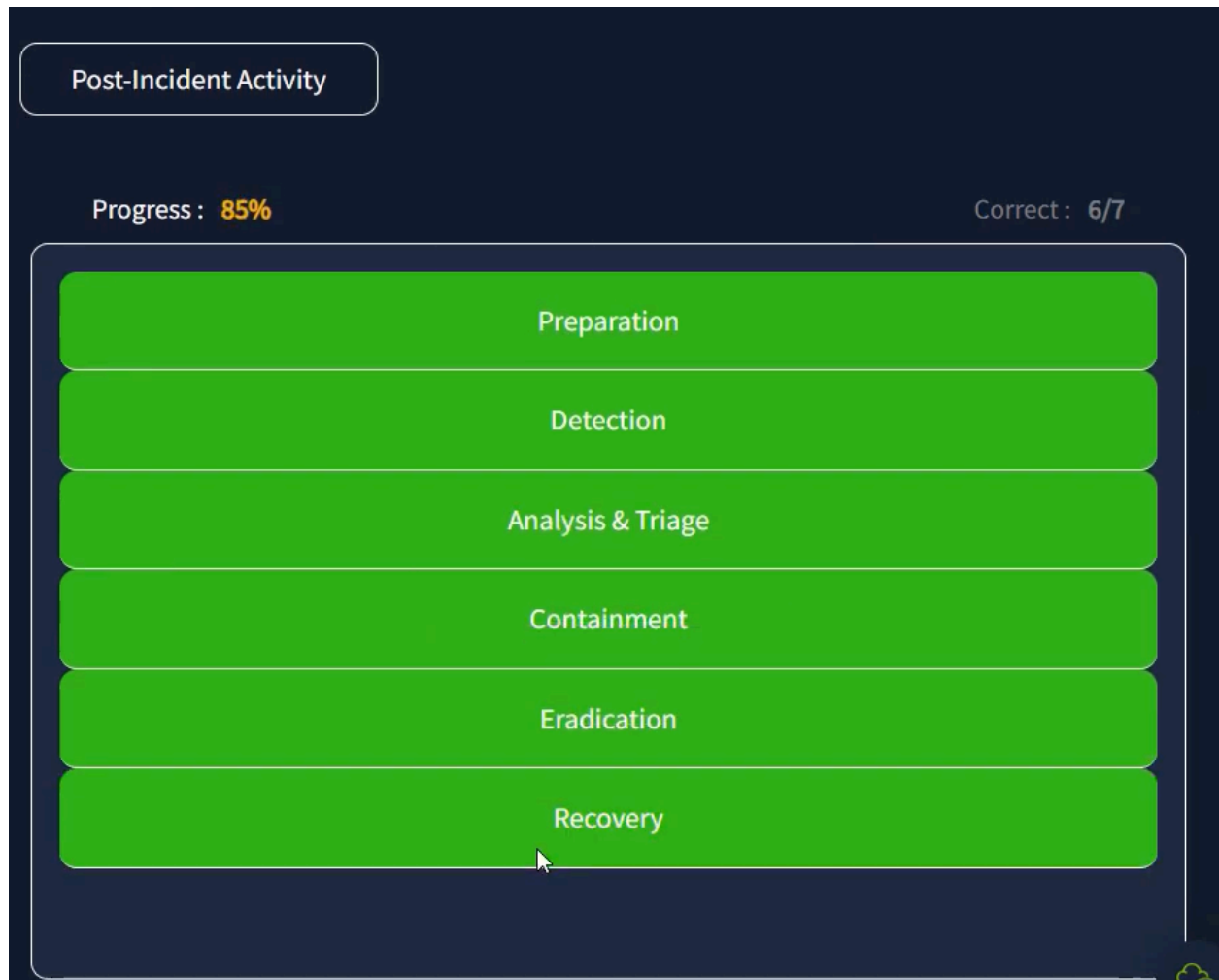
- Evaluate response effectiveness.
- Document findings and actions taken.
- Improve procedures, playbooks, and security controls.
- Strengthen preparedness for future incidents.

Preparation → Detection & Analysis → Containment, Eradication & Recovery → Post-Incident Activity This structured approach helps organizations respond efficiently, minimize damage, recover quickly, and continuously improve their security posture.

Answer the questions below

What is the value of the flag you receive after correctly matching the steps of the incident management process?

THM{Preparation.is.Key.for.Incident.Management}



Task 5 - Common Pitfalls During an Incident

1. Insufficient Hardening

- Systems are deployed without applying security best practices.
- Increases the likelihood of successful cyberattacks.
- Can be reduced through proper system hardening and the **Shift Left** security approach.

2. Insufficient Logging

- Lack of adequate logs reduces visibility into security events.
- Makes incident detection and investigation difficult.
- Can lead to delayed detection and inaccurate scope assessment.

3. Insufficient or Excessive Alerting

- **Too few alerts:** Security teams may miss threats.
- **Too many alerts:** Alert fatigue can cause analysts to ignore real incidents.
- Effective threat hunting and alert tuning help maintain a good signal-to-noise ratio.

4. Insufficient Determination of Incident Scope

- Underestimating scope may leave attackers active in the environment.
- Overestimating scope can cause unnecessary business disruption.
- Requires skilled analysts, preparation, and continuous training.

5. Insufficient Accountability

- Actions are discussed but not assigned to specific individuals.
- Important containment or recovery steps may never be executed.
- Incident managers should assign ownership and track completion of tasks.

6. Insufficient Backups

- Without reliable backups, recovery from ransomware or destructive attacks becomes difficult or impossible.
- Backups should be:
 - Regularly tested
 - Properly maintained
 - Isolated/offline when possible
- High Availability (HA) and Disaster Recovery (DR) environments alone may not protect against ransomware replication.

The most common incident response failures stem from **poor preparation, limited visibility, ineffective alerting, incorrect scope assessment, lack of accountability, and weak backup strategies**. Addressing these issues significantly improves an organization's ability to detect, respond to, and recover from cyber incidents.

Answer the questions below

What is the value of the flag you receive when you overcome the common pitfalls of a cyber incident?

THM{Avoiding.the.Common.IM.Mistakes}

Task 6 - Conclusion

To summarise:

- Incidents are a part of life. Incidents will happen, and therefore we need to prepare to deal with them.
- Not all events and alerts will lead to an incident. Even when there is an incident, we have different response levels that we can use to deal with the incident.
- Incident response focuses on answering the question of what has happened during an incident. Incident management focuses on effectively taking actions to close off the incident.
- There are many different roles and responsibilities during an incident. Even if you are not part of the blue team, you may be a first responder or may be called upon as a subject matter expert to help the blue team deal with an incident.
- Most organisations have their own incident management framework, but most are based on the NIST incident management framework that covers the four phases of Preparation, Detection & Analyses, Containment, Eradication & Recovery, and Post Incident Analysis.
- Several things can go wrong during an incident, and preparation can assist in reducing the impact that these pitfalls can have.

